

Experiment 1: Reconnaissance and foot printing

Aim: To perform foot printing and reconnaissance for a given target of evaluation.

Learning Outcomes:

After completion of this experiment, student should be able to

1. Describe basic steps in hacking
2. Describe active and passive reconnaissance.
3. Use various tools and utilities for information gathering about target of evaluation.

Theory:

Steps in hacking: Figure 1 below indicates basic steps involved in hacking.



Figure 1: Basic Hacking Process

Reconnaissance refers to the preparatory phase where an attacker seeks to gather information about a target prior to launching an attack. Reconnaissance can be active or passive reconnaissance. *Passive reconnaissance* involves gathering information regarding a potential target without the targeted individual's or company's knowledge. *Active reconnaissance* involves probing the network to discover individual hosts, IP addresses, and services on the network. This usually involves more risk of detection than passive reconnaissance.

Scanning refers to the pre-attack phase when the attacker scans the network for specific information on the basis of information gathered during reconnaissance

Gaining access is the phase where the real hacking takes place. Vulnerabilities discovered during the reconnaissance and scanning phase are now exploited to gain access.

Once a hacker has gained access, they want to keep that access for future exploitation and attacks.

Once hackers have been able to gain and maintain access, they cover their tracks to avoid detection by security personnel, to continue to use the owned system, to remove evidence of hacking, or to avoid legal action.

Footprinting is part of the preparatory pre-attack phase and involves accumulating data regarding a target's environment and architecture, usually for the purpose of finding ways to intrude into that environment. Footprinting can reveal system vulnerabilities and identify the ease with which they can be exploited. *Footprinting* is defined as the process of creating a blueprint or map of an organization's network and systems. Information gathering is also known as footprinting an organization. Footprinting begins by determining the target system, application, or physical location of the target. Once this information is known, specific information about the organization is gathered using nonintrusive methods.

Following tools and utilities can be used for information gathering

- *ping*
- *tracert*
- *nslookup*
- *whois*
- etc

Ping is a computer network administration utility used to test the reachability of a host on an IP network and to measure the round-trip time for messages sent from the originating host to a destination computer. Ping operates by sending ICMP *echo request* packets to the target host and waiting for an ICMP response. In the process it measures *round-trip time* and records any packet loss. The results of the test are printed in the form of a statistical summary of the response packets received, including the minimum, maximum, and the mean round-trip times, and sometimes the standard deviation of the mean. Ping does not evaluate or compute the time to establish the connection; it only gives the mean round-trip times of an established connection with an open session.

Tracert is a diagnostic tool for displaying the route (path) and measuring transit delays of packets across an IP network. The history of the route is recorded as the round-trip times of the packets received from each successive host (remote node) in the route (path); the sum of the mean times in each hop indicates the total time spent to establish the connection. Tracert proceeds unless all (three) sent packets are lost more than twice, then the connection is lost and the route cannot be evaluated. Tracert sends a sequence of three ICMP Echo Request packets addressed to a destination host. The time-to-live (TTL) value, also known as **hop limit**, is used in determining the intermediate routers being traversed towards the destination. Routers decrement packets' TTL value by 1 when routing and discard packets whose TTL value has reached zero, returning the ICMP error message ICMP Time Exceeded. Tracert works by sending packets with gradually increasing TTL value, starting with TTL value of 1. The first router receives the packet, decrements the TTL value and drops the packet because it then has TTL value zero. The router sends an ICMP Time Exceeded message back to the source. The next set of packets are given a TTL value of 2, so the first router forwards the packets, but the second router drops them

and replies with ICMP Time Exceeded. Proceeding in this way, traceroute uses the returned ICMP Time Exceeded messages to build a list of routers that packets traverse, until the destination is reached and returns an ICMP Echo Reply message.

The timestamp values returned for each router along the path are the delay (latency) values, typically measured in milliseconds for each packet. On UNIX systems, such as FreeBSD or Linux, it is available as a `traceroute` command in a terminal. On Microsoft Windows, it is named **tracert**. For IPv6 the tool sometimes has the name **traceroute6** or **tracert6**.

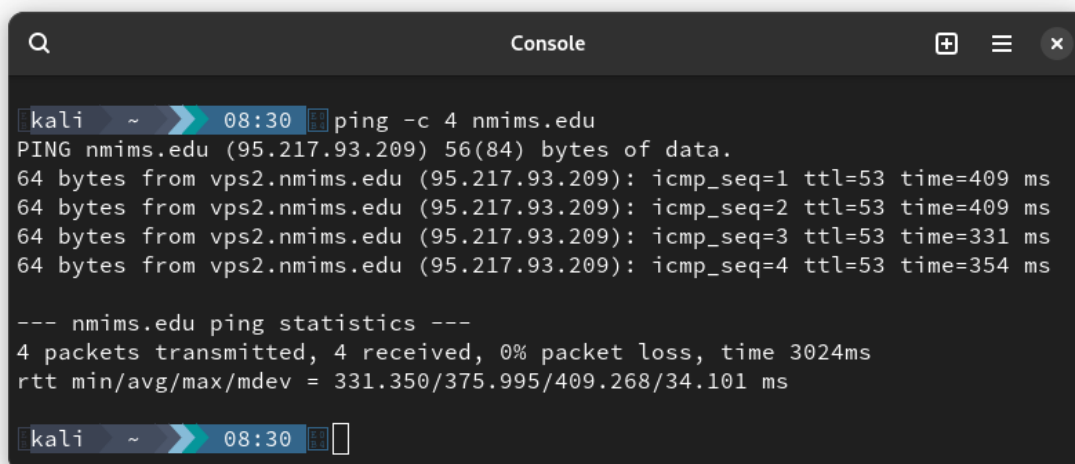
nslookup is a network administration command-line tool available for many computer operating systems for querying the Domain Name System (DNS) to obtain domain name or IP address mapping or for any other specific DNS record. nslookup operates in interactive or non-interactive mode. When used interactively by invoking it without arguments or when the first argument is - (minus sign) and the second argument is a host name or Internet address of a name server, the user issues parameter configurations or requests when presented with the nslookup prompt (>). When no arguments are given, then the command queries the default server. The - (minus sign) invokes subcommands which are specified on the command line and should precede nslookup commands. In non-interactive mode, i.e. when the first argument is a name or Internet address of the host being searched, parameters and the query are specified as command line arguments in the invocation of the program. The non interactive mode searches the information for a specified host using the default name server.

WHOIS is a query and response protocol that is widely used for querying databases that store the registered users or assignees of an Internet resource, such as a domain name, an IP address block, or an autonomous system, but is also used for a wider range of other information. The protocol stores and delivers database content in a human-readable format.

Procedure:

Task 1: Finding IP address

1. On command prompt, read online help for ping using `ping /?`
2. Use *ping* to find the IP address of the target. Note the IP address and RTT.



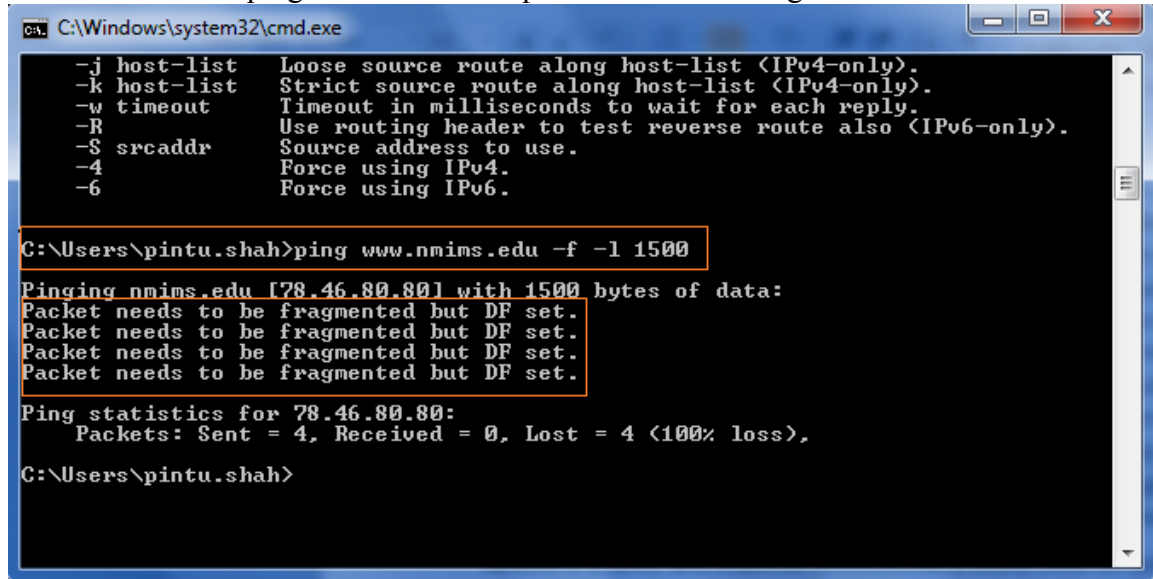
```
kali ~ 08:30 ping -c 4 nmims.edu
PING nmims.edu (95.217.93.209) 56(84) bytes of data:
64 bytes from vps2.nmims.edu (95.217.93.209): icmp_seq=1 ttl=53 time=409 ms
64 bytes from vps2.nmims.edu (95.217.93.209): icmp_seq=2 ttl=53 time=409 ms
64 bytes from vps2.nmims.edu (95.217.93.209): icmp_seq=3 ttl=53 time=331 ms
64 bytes from vps2.nmims.edu (95.217.93.209): icmp_seq=4 ttl=53 time=354 ms

--- nmims.edu ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3024ms
rtt min/avg/max/mdev = 331.350/375.995/409.268/34.101 ms

kali ~ 08:30
```

Task 2: Finding maximum Frame Size

1. Use the command ping with -f and -l options as shown in figure 1 below.



```
C:\Windows\system32\cmd.exe

-j host-list      Loose source route along host-list <IPv4-only>.
-k host-list      Strict source route along host-list <IPv4-only>.
-w timeout        Timeout in milliseconds to wait for each reply.
-R               Use routing header to test reverse route also <IPv6-only>.
-S srcaddr        Source address to use.
-4               Force using IPv4.
-6               Force using IPv6.

C:\Users\pintu.shah>ping www.nmims.edu -f -l 1500

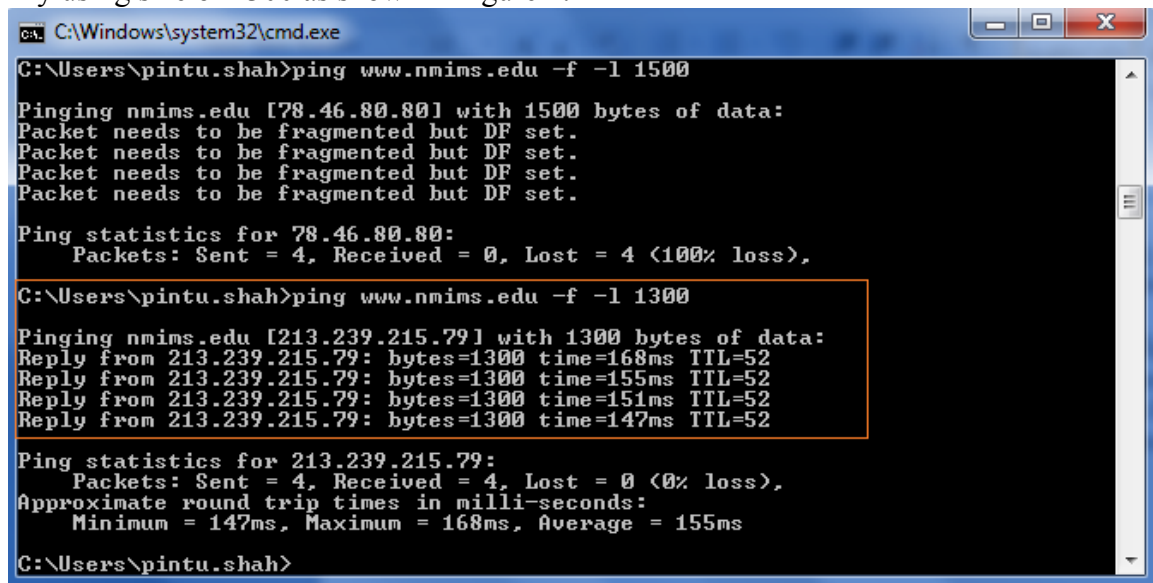
Pinging nmims.edu [78.46.80.80] with 1500 bytes of data:
Packet needs to be fragmented but DF set.
Packet needs to be fragmented but DF set.
Packet needs to be fragmented but DF set.
Packet needs to be fragmented but DF set.

Ping statistics for 78.46.80.80:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\Users\pintu.shah>
```

Figure 1: finding maximum frame size

2. The display **Packet needs to be fragmented but DF set** means that the frame is too large to be on the network and needs to be fragmented. Since we used -f switch with the ping command, the packet was not sent, and the ping command returned this error.
3. Try using size of 1300 as shown in figure 2.



```
C:\Windows\system32\cmd.exe

C:\Users\pintu.shah>ping www.nmims.edu -f -l 1500

Pinging nmims.edu [78.46.80.80] with 1500 bytes of data:
Packet needs to be fragmented but DF set.
Packet needs to be fragmented but DF set.
Packet needs to be fragmented but DF set.
Packet needs to be fragmented but DF set.

Ping statistics for 78.46.80.80:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\Users\pintu.shah>ping www.nmims.edu -f -l 1300

Pinging nmims.edu [213.239.215.79] with 1300 bytes of data:
Reply from 213.239.215.79: bytes=1300 time=168ms TTL=52
Reply from 213.239.215.79: bytes=1300 time=155ms TTL=52
Reply from 213.239.215.79: bytes=1300 time=151ms TTL=52
Reply from 213.239.215.79: bytes=1300 time=147ms TTL=52

Ping statistics for 213.239.215.79:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 147ms, Maximum = 168ms, Average = 155ms

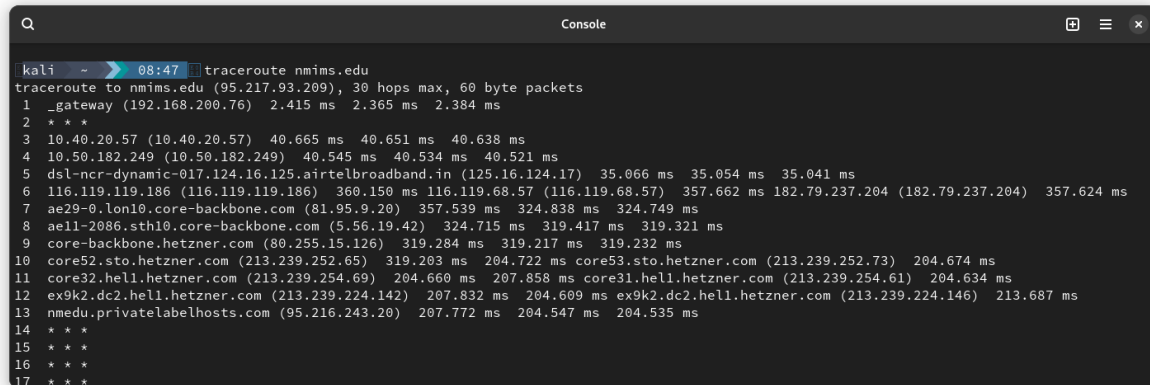
C:\Users\pintu.shah>
```

Figure 2: ping using size of 1300 bytes

4. Since ping is successful, we can see that the maximum packet size is less than 1500 bytes and more than 1300 bytes
5. Try with different sizes to find maximum frame size. Note the maximum size.

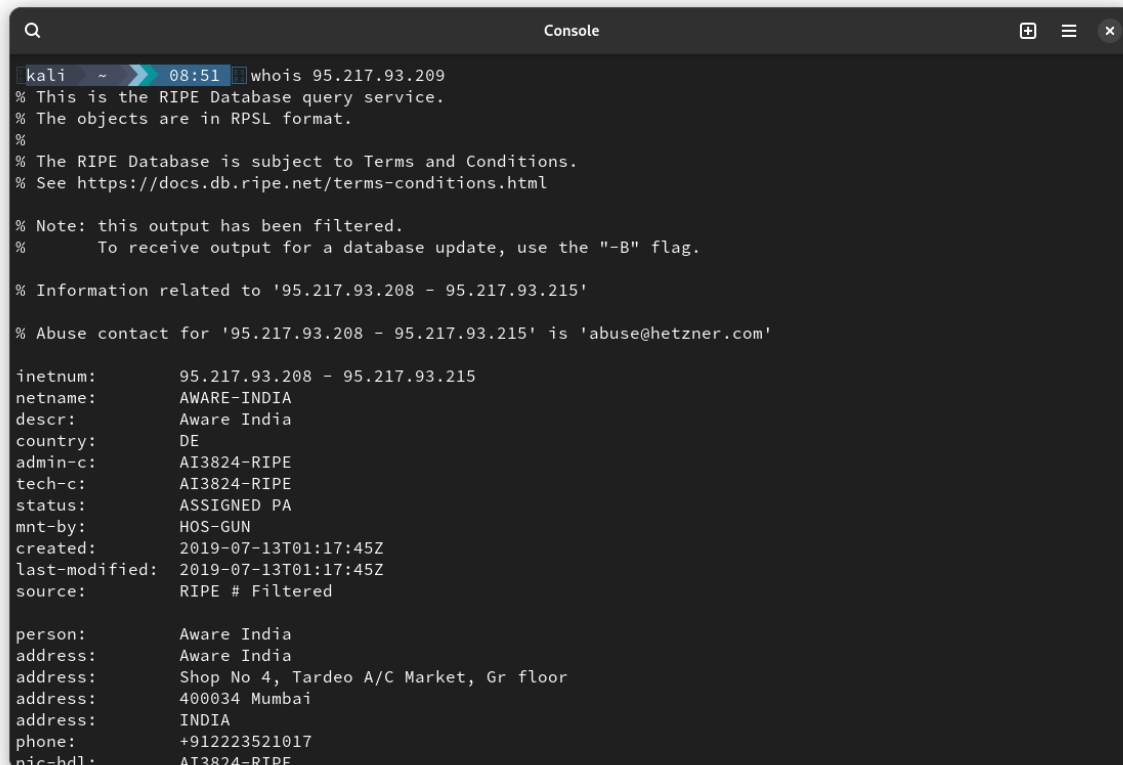
Task 3: Trace route to the target using tracer

1. Execute command `tracert www.nmims.edu` from command prompt.



```
kali ~ 08:47 [~] traceroute nmims.edu
traceroute to nmims.edu (95.217.93.209), 30 hops max, 60 byte packets
 1 _gateway (192.168.200.76)  2.415 ms  2.365 ms  2.384 ms
 2 * * *
 3 10.40.20.57 (10.40.20.57)  40.665 ms  40.651 ms  40.638 ms
 4 10.50.182.249 (10.50.182.249)  40.545 ms  40.534 ms  40.521 ms
 5 dsl-ncr-dynamic-017.124.16.125.airtelbroadband.in (125.16.124.17)  35.066 ms  35.054 ms  35.041 ms
 6 116.119.119.186 (116.119.119.186)  360.150 ms  116.119.68.57 (116.119.68.57)  357.662 ms  182.79.237.204 (182.79.237.204)  357.624 ms
 7 ae29-0.lon10.core-backbone.com (81.95.9.20)  357.539 ms  324.838 ms  324.749 ms
 8 ae11-2086.sth10.core-backbone.com (5.56.19.42)  324.715 ms  319.417 ms  319.321 ms
 9 core-backbone.hetzner.com (80.255.15.126)  319.284 ms  319.217 ms  319.232 ms
10 core52.sto.hetzner.com (213.239.252.65)  319.203 ms  204.722 ms  core53.sto.hetzner.com (213.239.252.73)  204.674 ms
11 core32.hell.hetzner.com (213.239.254.69)  204.660 ms  207.858 ms  core31.hell.hetzner.com (213.239.254.61)  204.634 ms
12 ex9k2.dc2.hell.hetzner.com (213.239.224.142)  207.832 ms  204.609 ms  ex9k2.dc2.hell.hetzner.com (213.239.224.146)  213.687 ms
13 nmedu.privatelabelhosts.com (95.216.243.20)  207.772 ms  204.547 ms  204.535 ms
14 * * *
15 * * *
16 * * *
17 * * *
```

2. Analyze the output



```
kali ~ 08:51 [~] whois 95.217.93.209
% This is the RIPE Database query service.
% The objects are in RPSL format.
%
% The RIPE Database is subject to Terms and Conditions.
% See https://docs.db.ripe.net/terms-conditions.html
%
% Note: this output has been filtered.
%       To receive output for a database update, use the "-B" flag.
%
% Information related to '95.217.93.208 - 95.217.93.215'
%
% Abuse contact for '95.217.93.208 - 95.217.93.215' is 'abuse@hetzner.com'
inetnum:        95.217.93.208 - 95.217.93.215
netname:        AWARE-INDIA
descr:          Aware India
country:        DE
admin-c:        AI3824-RIPE
tech-c:         AI3824-RIPE
status:         ASSIGNED PA
mnt-by:         HOS-GUN
created:        2019-07-13T01:17:45Z
last-modified:  2019-07-13T01:17:45Z
source:         RIPE # Filtered

person:         Aware India
address:         Aware India
address:         Shop No 4, Tardeo A/C Market, Gr floor
address:         400034 Mumbai
address:         INDIA
phone:          +912223521017
nic-hdl:        AI3824-RIPE
```

3. Note the number of hops required to reach the destination.

14 Hops

Task 4: Using nslookup to find domain related information

1. Execute nslookup from command prompt in interactive mode.
2. Collect and note following information using nslookup.
 - a. Authoritative server

```
kali ~ 09:08 nslookup -type=mx nmims.edu
Server:      192.168.200.76
Address:     192.168.200.76#53

Non-authoritative answer:
nmims.edu    mail exchanger = 0 nmims-edu.mail.protection.outlook.com.

Authoritative answers can be found from:
nmims.edu    nameserver = ns.awareindia.com.
nmims.edu    nameserver = ns1.awareindia.com.
```

- b. Non authoritative server

```
kali ~ 09:08 nslookup -type=ns nmims.edu
Server:      192.168.200.76
Address:     192.168.200.76#53

Non-authoritative answer:
nmims.edu    nameserver = ns.awareindia.com.
nmims.edu    nameserver = ns1.awareindia.com.

Authoritative answers can be found from:
```

- c. CNAME
- d. Mail server information

Task 5: Analyzing domain and IP address queries using whois

1. Use whois utility available at www.dnsstuff.com.
2. Collect and note following information related to do domain
 - a. Registrant of domain
NMIMS
 - b. Date of registration of domain
14-Jan-1998

```
kali ~ 09:12 nslookup -type=mx nmims.edu
Server: 102.168.200.76
Address: 102.168.200.76

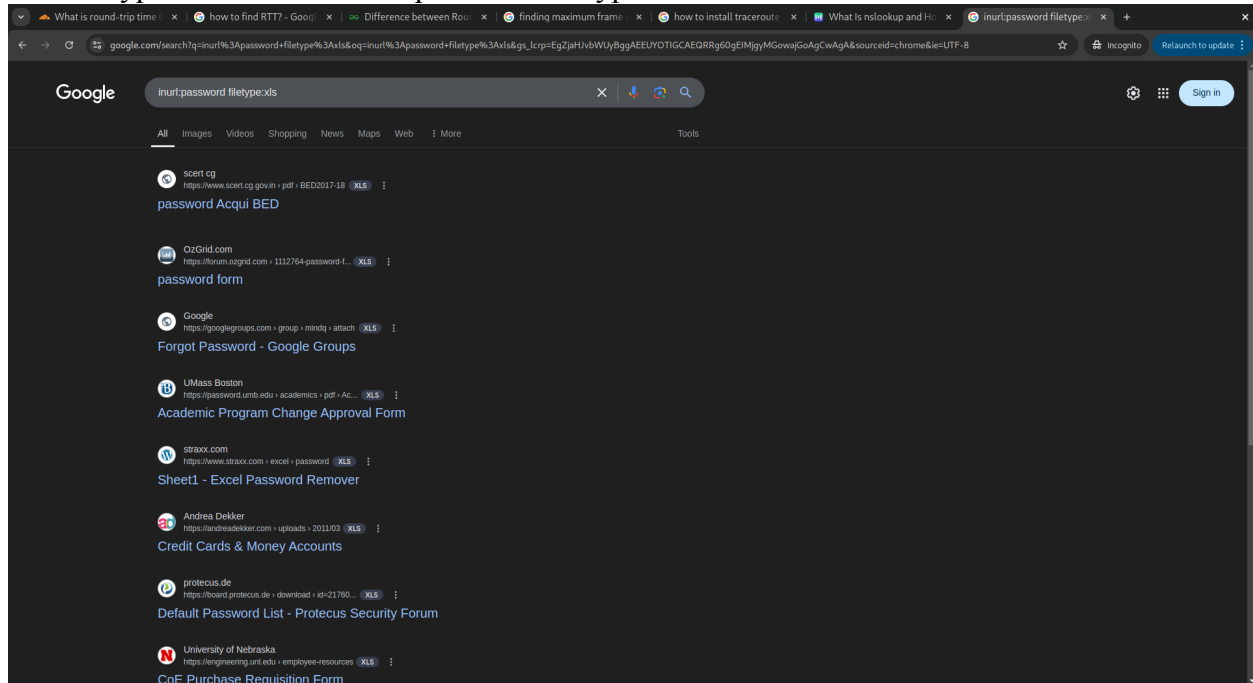
Domain Name: NMIMS.EDU
Registrant:
Narsee Monjee Institute of Management
Juhu Vile Parle Development
Scheme Vile Parle (West)
Mumbai, Maharashtra 400 058
India
Administrative Contact:
Pankaj Jaiswal
Dotcom Service India Pvt. Ltd.
101/102 Tirupati Udyog Premises Opp Petrol Pump
I.B.Patel Road Goregaon East
Mumbai, Maharashtra 400063
India
+91.2226855700
webmaster@worldindia.com
Technical Contact:
Pankaj Jaiswal
Dotcom Service India Pvt. Ltd.
101/102 Tirupati Udyog Premises Opp Petrol Pump
I.B.Patel Road Goregaon East
Mumbai, Maharashtra 400063
India
+91.2226855700
webmaster@worldindia.com
Name Servers:
NS1.AWAREINDIA.COM
NS.AWAREINDIA.COM
```

- c. Date of expiry of domain
31-Jul-2025
- d. Name servers
NS1.AWAREINDIA.COM
NS.AWAREINDIA.COM
- e. Administrative contact details
Pankaj Jaiswal
Dotcom Service India Pvt. Ltd.
101/102 Tirupati Udyog Premises Opp Petrol Pump
I.B.Patel Road Goregaon East
Mumbai, Maharashtra 400063
India
+91.2226855700
webmaster@worldindia.com
- f. Technical contact details
Pankaj Jaiswal
Dotcom Service India Pvt. Ltd.
101/102 Tirupati Udyog Premises Opp Petrol Pump
I.B.Patel Road Goregaon East

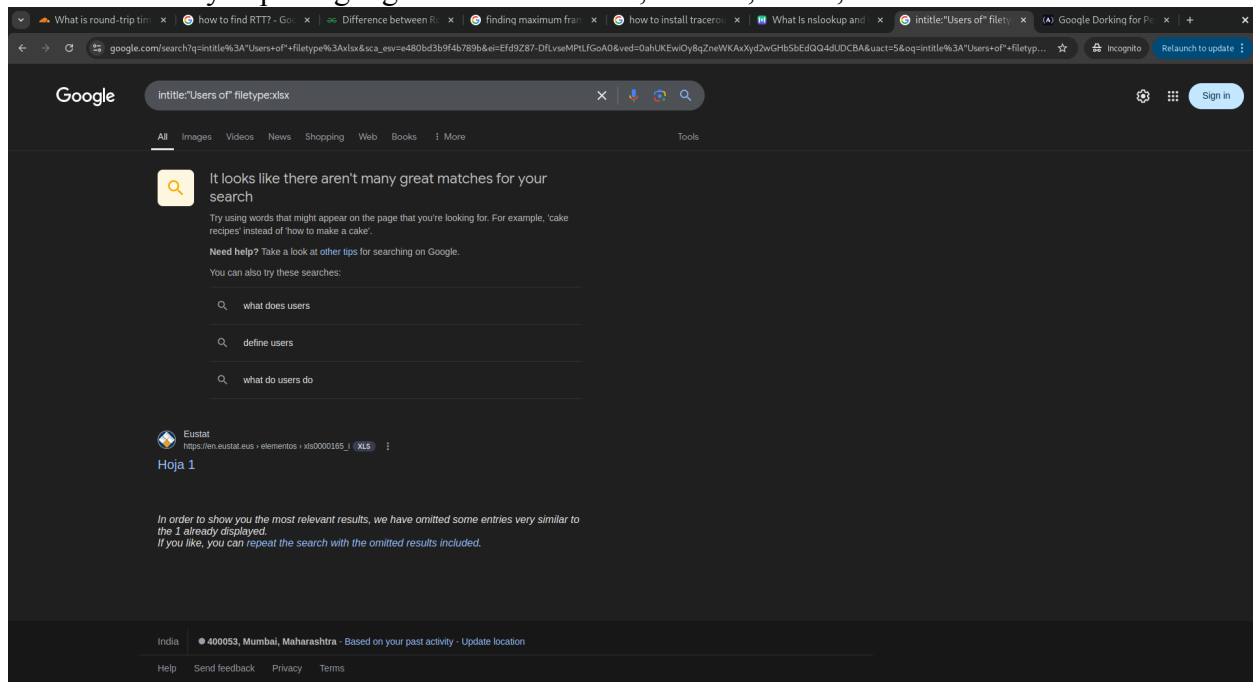
Mumbai, Maharashtra 400063
India
+91.2226855700
webmaster@worldindia.com

Task 6: Information Gathering using advanced Google Hacking Techniques

1. Open google.com
2. Type in search bar `inurl:password filetype:xls`



3. Similarly explore google dorks like `intitle`, `allinurl`, `cache`, `allintitle` etc.



Review questions:

1. How does tracert (trace route) find the route that the trace packets are (probably) using?
2. We saw before:
 - a. Request timed out
 - b. Packet needs to be fragmented but DF set
 - c. Reply from XXX.XXX.XXX.XXX: TTL expired in transit

What ICMP type and code are used for the ICMP Echo request?

3. Analyze and determine each of the following DNS resource records:
 - SOA
 - NS
 - A
 - AAAA
 - PTR
 - CNAME
 - MX
 - SRV
4. Evaluate the difference between an authoritative and non-authoritative answer.
5. Determine when you will receive request time out in nslookup?
6. Why do you get Connection timed out or Connection failed errors when using whois?
7. What do you understand by Google dorks?

How does **tracert** (trace route) find the route that the trace packets are probably using?

tracert works by sending **ICMP Echo Request** or **UDP packets** to the target host with increasing **TTL (Time to Live)** values:

1. The **TTL field** in the packet header is decreased by 1 at each hop.
2. When the TTL reaches **0**, the router handling the packet sends back an **ICMP Time Exceeded** message (Type 11, Code 0).
3. **tracert** records the source IP address of the ICMP message, identifying the intermediate router.
4. This process repeats with incremented TTL until the destination host is reached, which replies with an **ICMP Echo Reply** or, for UDP packets, triggers a "Port Unreachable" error.

What ICMP type and code are used for the ICMP Echo request?

- **ICMP Echo Request:** Type **8**, Code **0**.
- **ICMP Echo Reply:** Type **0**, Code **0**.

DNS Resource Records Analysis

1. **SOA (Start of Authority):** Contains metadata about the zone, such as:
 - Primary authoritative nameserver.
 - Email of the zone admin.
 - Serial number (to track updates).
 - Refresh, retry, and expiration intervals for caching.
2. **NS (Name Server):** Lists the authoritative nameservers for the domain.
3. **A (Address Record):** Maps a domain name to an **IPv4 address**.
4. **AAAA (Quad-A Record):** Maps a domain name to an **IPv6 address**.
5. **PTR (Pointer Record):** Maps an **IP address to a domain name** (reverse DNS lookup).
6. **CNAME (Canonical Name Record):** Creates an alias for a domain name, redirecting it to another domain.
7. **MX (Mail Exchange Record):** Specifies the mail server(s) for a domain and their priority.
8. **SRV (Service Record):** Specifies services (e.g., SIP, LDAP) and their locations, including port numbers.

Difference Between an Authoritative and Non-Authoritative Answer

- **Authoritative Answer:** Provided directly by a DNS server that holds the original zone file for the domain. The response is trustworthy and accurate.
- **Non-Authoritative Answer:** Provided by a caching or recursive DNS server that queried authoritative servers previously. The data may be outdated if TTL has expired.

When Do You Receive "Request Timed Out" in nslookup?

This occurs when:

1. The target DNS server is **unreachable**.
2. There is **no response** from the server within the timeout period.
3. A **firewall** or security policy blocks the DNS query.

Why Do You Get "Connection Timed Out" or "Connection Failed" Errors When Using whois?

1. **Server Unreachable:** The whois server is down or unreachable.
2. **Port Blocking:** Firewalls or ISPs block port **43** (used by whois).
3. **Rate-Limiting:** The whois server limits the number of queries from a client to prevent abuse.

What Do You Understand by Google Dorks?

Google Dorks refer to using advanced search operators in Google to discover:

1. **Sensitive data** exposed online (e.g., passwords, configuration files).
2. **Specific file types** (e.g., `filetype:pdf`, `filetype:txt`).
3. **Indexed vulnerabilities** or misconfigurations (e.g., `intitle:"index of"`).
4. Examples:
 - `site:example.com filetype:pdf` to find PDFs on a site.
 - `inurl:admin` to locate admin login pages.
 - `intitle:"index of" "passwords"` to find directories containing password files.

Google Dorks are often exploited in **ethical hacking** and **OSINT (Open-Source Intelligence)**.